INTRODUCTION TO CYBERSECURITY

CYBERSECURITY → This is the technology and process that is designed to protect networks and devices from attack, damage, or unauthorized access.

ADVANTAGES

- Protection of business
- Increased productivity
- Inspires Customer Confidence
- Stops your website from Crashing
- Protection for your Customers or clients.

WHY CYBER SECURITY

Confidentiality, Integrity and Availability have served as the industry standard for Computer Security since the time of first mainframes.

1. CONFIDENTIALITY :- The principles of Confidentiality assert that information and functions can be accessed only by authorized parties. E.g Military parties.

2. INTEGRITY :- The principles of integrity assert that information and functions can be added, altered, or removed only by authorized people and means.
Example; incorrect data entered by a user in the database.

3. AVAILABILITY :- The principles of availability assert that systems, functions and data must be available on demand according to agreed-upon parameters based on levels of service.

Threats to CIA.

+ Cybercrime
+ Hacking

+ Cybercrime is any criminal activity that involves a Computer, network device or a network.
Most Cybercrimes are carried out in order to generate profit for the Cyber

Criminals.

Cybercrimes are carried out against computer or devices directly to damage or disable them, spread malware, steal secret information, etc.

TYPES OF CYBERCRIME

1. **COMPUTER ASSISTED CRIMES**: Criminal activities carried out using computers as mere tools and are not specific to computers.
   Example: Fraud, Denial of service (DOS)

2. **COMPUTER AS THE TARGET CRIMES**: Criminal activities focused on systems, servers, networks, and data stored on these systems. Example: Sniffing, Viruses

3. **COMPUTERS INCIDENTIAL TO THE CRIMES**: These are the crimes where a computer is related or incidental to the crime. A crime could occur without the use of the computer. Example; List of customer for traffickers.

Examples

1. Confidentiality → Encryption, Multi authentication
2. Integrity → Hashing & checksums
3. Availability → Backups & regular updates

In other words, the opposite of C.I.A is D.A.D - Meaning; Disclosure, alteration and Denial.

Methods Of Disclosure

1. Password Attack
2. Phishing Attack
3. Privacy Violation

Methods of Alteration

1. Direct Modification
2. Malware / Ransomware

Methods of Denial

1. D.D.O.S → Distributed Denial of Service
2. D.O.S → Denial of Service.

→ DDOS → Multiple Compromised devices (often a global network of infected Computers, routers, or Smart devices (called a botnet) flood the target all at once. Because traffic

comes from thousands of different locations, it is incredibly difficult to stop.

→ DOS → A single computer or internet connection floods a target server with traffic to exhaust its resources.

It is relatively easy to block by identifying and banning the single offending IP address.

Who is a Hacker?

A hacker is an individual highly skilled in information technology who manipulates, explores, or bypasses computer systems to solve problems, achieve goals, or exploit vulnerabilities either authorized or unauthorized.

Types of Hackers.

- White - Hat Hackers (Ethical Hackers):

Cybersecurity professionals who use their expertise legally to identify and fix security vulnerabilities, helping

organizations protect their data & they are authorized.

- Gray - Hat Hackers : Individuals who fall in - between the Black - Hat and White - Hat hackers. They are indecisive they go for the highest bidders.

- Black - Hat Hackers (Cybercriminals): Malicious individuals who exploit network weaknesses to bypass security measures for personal gain, theft, sabotage, or installing malware.

THREAT ACTORS

- Purple → Offence and Defend
- Blue → Defend
- Red → Attack

THREAT ACTORS

1. SCRIPT KIDDIES :- These are inexperienced threat actors who rely on pre-written scripts, automated tools, and open-source software created by skilled hackers to conduct cyberattacks.

2. ORGANISED CRIMES :- An individual or structured group of three or more persons acting in concert for financial or material gain.

3. INSIDER THREATS :- This is a distinct class of cybersecurity threat actor who leverages their authorized access - such as employees, contractors, or business partners - to compromise an organization's data, systems, or facilities.
Their skill level may vary.

4. NATION STATE :- This is a highly sophisticated, state-sponsored hacking group backed by a government to conduct

Cyber espionage, infrastructure sabotage, or intelligence gathering.

* They are sponsored by their government to enrich their economy, while their government protects them.

5. HACKTIVISTS :- They hack strictly for political or social reasons.

They are a distinct class of cyber threat actors driven by political, idealogical, or social agendas rather than financial gain.

Examples Of Cybercrimes / Cyberattacks.

1. Equifax : Equifacts were successful because there was failure in all C.I.A trials.

N/B: As a cybersecurity professional or analyst, you must have a **written authorization** before you hack, and you must report your findings directly to your contractor, then, you must not

Cause unnecessary damages.

27/05/26 1. & SECURITY CONTROLS IN CYBERSEC.

RISK MANAGEMENT IN CYBERSECURITY.

This is the processing of identifying, evaluating and reducing threats to an acceptable level.

Basic Steps

1. Identify the Risk
2. Access the risk
3. Treat the risk
4. Monitor the risk
5. Document the risk

1. IDENTIFY THE RISK: This is the process of figuring out what could go wrong in the first place.
2. ACCESS THE RISK: This means figuring out how serious a potential problem is and how likely it is to happen, so you can decide what to do about it.
3. TREAT THE RISK: Treating the risk

means ~~using~~ deciding what you're actually going to do about it after you've identified and assessed it.

4. MONITOR THE RISK: Monitoring the risk means Continuously watching to see if the risks you identified and treated are changing, getting better, or getting worse.

5. DOCUMENTS THE RISK: Document the risk means writing down everything you found so you can track it, make decisions and prove you actually looked at it later.

RISK TREATMENT

This simply means what to do after identifying the risk.

There are four (4) ways to treat the risk;

1. Avoid the risk
2. Reduce the risk
3. Transfer the risk
4. Accept the risk

1. **AVOIDING THE RISK** :- means eliminating the risk entirely by not doing the activity that creates it.

How to Avoid the Risk

+ Disabling unused ports
+ Remove unsupported Softwares
+ Stop Collecting unnecessary Customer data.

2. **REDUCING THE RISK** :- this is also called risk mitigation, it means taking action to lower either how likely an attack is, or how bad the damage would

be if it happens.

How to Reduce the Risk.

+ Enable multi-factor authentication
+ Train users
+ Monitor Log in's

3 Risk TRANSFER : means shifting the financial or operational burden of a risk to another party.

Examples

+ Insurance
+ Outsourcing to a provider
+ Manage

4. ACCEPTING THE Risk : means acknowledging the risk is there, and deciding not to do anything about it.

Reasons for Accepting the Risk

+ Cost of fixing it is too high
+ Impact is low
+ Risk is already assetible

ZERO TRUST

Zero trust as the name implies to 'Never trust, always verify'.

It is making sure that the user has rights to assess the information before giving out the access.

It includes;

- Strict identification verification
- Least privilledge access
- Multi-factor authentication
- Monitor and log all traffic

NON - REPUDIATION

This means ensuring that the party in a Congregation can not deny the authenticity of their signature on a document.

It means having authentic signature and

AAA IN CYBERSECURITY

A → Authentication
A → Authorization and
A → Accounting

It's the framework and backbone for controlling and tracking who accesses what's on a network/system.

- Authentification → Who you are?
  Verifying the identity of a user or device.

- Authorization → What are you allowed to do?
  Deciding what an authenticated user can access after they're identified.

- Accounting → What did you do?
  Logging and tracking user activity for auditing, billing and forensics.

GAP ANALYSIS

It means an assessment that an organization used to compare their current Security posture, with a set standard, Best practices or regulatory requirements. 4 improvements

It simply means checking whether your Computer needs updates.

2. SECURITY POLICIES AND PROCEDURES.

They are the 'rules and playbooks' that tell people how to protect assets and what to do when things go wrong.

3. TECHNICAL SECURITY CONTROLS.

This is also known as logical Security Controls. They are mechanisms implemented in hardware, Software or firmware that automate the process of preventing, detecting and responding to Security threats.

Examples

- Access Control Mechanisms
- firewalls
- IDS → Intrusion Detection System
- IPS → Intrusion Prevention System
- Encryption
- Anti virus and Anti malware.
- VPN → Virtual Private Network used to create a secure internet connection mainly used by remote workers to have a secure internet connection to their company.

4 OPERATIONAL SECURITY CONTROL

They are the day-to-day methods and procedures implemented by an organisation to ensure the security of their assets and information. Examples:

- Security Awareness training

5 Physical Security Control

As the name implies, they are measures taken to protect the actual hardware and facilities that house the systems, methods and data's. Examples; CCTVs, employed Security men, access card, alarms, fencing, gates etc.

Security Control Types

* Preventive Control: ability to stop before it occurs. Examples; fireworks
* Detective Control: Attempt to effect ~~events~~ that results to result in a Security.
  Examples; SEM;-
  IDS-
  Motion detectors.
* Corrective Control: Attempt to an incident that has occurred. Example
  - Restoring backups
* Deterrant Control: Attempts to discourage

a threat. Examples; Guard dogs
c Directive Controls: provides Corrections on how organization Systems should perform
Examples; policies and procedures

LAYERED SECURITY

this is also called Defense In Depth
It is the idea of stacking multiple security Controls so that if one fails, the other still protect you.

THREAT MOTIVATION

a. Data Exfiltration
b. Espionage (spying)
c. Service Destruction (DOS → Denial of Service)
d. Blackmails
e Political Benefits like activists
f Ethical reasons
g Revenge
h Disruption / Disorder

Attributes Of Actors (Hackers).

- Internal / External
- Resources / Funding
- Level of Sophistication (skill level of the actors).

Threat Vectors And Attack Surface.

1. Email or SMS
2. Image based
3. File based
4. Voice Call
5. Removable devices like flash drives
6. Vulnerable softwares like client based & agentless
7. Outdated systems → Unsupported systems and applications.
8. Unsecured Networks
9. Open service port
10. Default credentials eg wifi default logins. (username & password: Admin)

11 Supply chain

28/05/26

VULNERABILITIES

This refers to witness in a system that can be exploited by a threat actor

Examples

i Weak passwords
ii Outdated Operating System
iii Memory Injection and buffer Overflow: They are two classic ways attackers mess with a program's memory to run code they control.

Memory Injection:- is when an attacker puts malicious code directly into the memory of a running process and tricks it into executing that code.

Buffer Overflow:- is a vulnerability where a program writes more data into a memory buffer than it can hold, causing the excess data to overwrite adjacent memory. It's one of the oldest & still common ways to get remote code execution.

iv Race Condition :- is when two or more processes or threads try to access and change the same time, and the outcome depends on which one "wins" the race.

If an attacker can manipulate the thing they can force the system into an insecure state - It's a TOC/TOU problem

TOC - Time Of Check

TOU - Time Of Use

v Malicious Update : is when legitimate software gets compromised and ships malware to its users through the normal update mechanism.

vi SQL Injection : is where an attacker inserts malicious SQL code into an input field to manipulate a database query.

SQL → Structured Query Language.

v Cross Site Scripting (XSS) : is an attack where an attacker injects malicious Javascript

into a website, and it runs in other user's browsers.

MOBILE & DEVICE VULNERABILITIES

This refers to witness that potentially be exploited by attackers to gain unauthorized access to your device data.

This includes outdated operating systems, Examples: Unsecured network connection, physical access, system flaws, and user's behaviour of sharing passwords anyhow.

i. Rooting: means getting root/admin-level access to an operating system by bypassing its built-in restrictions.

ii. Side Loading: means installing an app on a device from outside the official app store.

iii. Zero Day Vulnerability: this is a Software

flaw that's unknown to the vendor and has no patch available yet.

SIGNS OF ATTACK

1. **Malware** :- Any software intentionally designed to cause damages to (malicious softwares) Computers, network

Malwares includes

a. **Virus** - Attaches itself to legit files and Spreads when you run/share those files.

b. **Worm** - Self-replicates and spreads across network without user action.

Key Difference b/w Worm & Virus.

Worm does not need your permission to spread, it does not attach itself to any application.

Virus needs your permission

How to Protect Against

- x Anti-Virus
- x Anti-Malware
- x Updates
- x Network Segmentation

x Disable Unnecessary devices

x Trojan horse :- disguises itself as legit software to trick you into installing it E.g ads.

• Ransomware :- Encrypts and logs you out of your files and demands payment to decrypt.

How To Mitigate Ransomware

- User Training
-

d Spyware :- Hides and records what you do like keystrokes, Screenshots, mic, location. Used for Corporate espionage, stalking and stealing Credentials.

Characteristics

x Communication

x Surveillance

x Data Collection

How to Mitigate Spyware

- Patch Management

- Secure Browsing habit
- User Training
- Anti Virus

e Rootkit :- Hides malware from the OS and antivirus by hooking into low-level system functions.
It is hard to detect and remove.
How to Mitigate Rootkit
x Secure Boot
x System Hardening
to.

f Logic Bombs : malicious code hidden inside a program that stays dormant until a specific condition is met. Once triggered, it executes its destructive payload.
How to Mitigate
x Code Review
x Access Control
x Change Management

g Key Loggers : a type of Surveillance software

or hardware. Once installed on a system has the capacity to record every keyboard stroke made on a system.

How to Mitigate

- Two-factor authen
- Use on screen keyboard
- Anti-virus / Anti-malware
- Regular backups
- Updating operating system.

Bloatware: is software that comes pre-installed on your device and takes up space, resources, or attention without adding real value for you.

Mitigation

- Careful selection of devices
- Custom OS installion

2 D.D.O.S